



Promotion 2024 – 3^e année cycle ingénieur

Majeure OCC



DIGITAL
FUTURE IS DIGITAL

ACCESS POINT COMPANY

Pôle IT

CACHAN

Tuteur école : Soha Lagneb

Tuteur entreprise : Amir Achache

CONSULTANT CYBERSECURITE ET RESEAUX

Une seconde année au service de ma montée en compétence

SAMY ACHACHE

Document confidentiel

Table des matières

Remerciements	2
Resume	3
Introduction	4
1 Positionnement de mon alternance et problematique	6
1.1 Etude du secteur economique de la cyberscurite	6
1.2 Engagement DD-RSE du secteur de la cyberscurite	7
1.3 Cadre reglementaire et normatif	8
1.4 Positionnement d'AccessPointCompany au sein de son secteur d'activite	9
1.5 Role de mon alternance et mon positionnement au sein de l'entreprise	10
1.6 Comparaison avec ma premiere annee d'alternance	11
2 Presentation de mon alternance	13
2.1 Objectifs de mes missions en apprentissage et projets confies	13
2.2 Plan de route	13
2.3 Analyse des besoins	14
2.4 Methodes et outils utilises	14
2.5 Equipes concernees	15
2.6 Exemple d'une semaine type	15
3 Deroulement de mon alternance	16
3.1 Presentation des differentes missions	16
3.2 Mise en œuvre des outils et methodes choisies	20
3.3 Difficultes techniques rencontrees durant les missions	21
3.4 Realisations individuelles et en equipe	21
4 Demarche scientifique et recherche : reduire les faux positifs en supervision de securite	23
4.1 Introduction	23
4.2 Etat de l'art	24
4.3 Methodes et materiaux	25
4.4 Resultats	26
4.5 Discussion	27
4.6 Conclusion du chapitre	27
5 Bilan de l'annee ecoulee	29
5.1 Competences developpees, acquises et manquantes	29
5.2 Lien avec ma majeure	29
5.3 Difficultes rencontrees et solutions apportees	30
5.4 Succes, bonnes pratiques et positionnement par rapport aux objectifs initiaux	30

5.5	Retours de mon tuteur et de mes pairs	31
5.6	Plan de carriere a court et moyen terme	32
Conclusion		32
Glossaire et liste des sigles		34
Annexes		35

Remerciements

Cette cinquieme annee cloture cinq annees d'un parcours qui m'a mene de la decouverte de la cybersecurite a une contribution de plus en plus active au sein d'AccessPointCompany, et je souhaite remercier toutes les personnes qui y ont contribue. Je remercie a nouveau l'ESILV Paris de m'avoir permis de mener ce projet de fin de cycle sur un sujet toujours aussi central pour les entreprises, et pour une formation d'ingenieur qui m'a donne les cle de lecture necessaires pour affronter des problematiques de plus en plus concretes.

Je remercie tout particulierement mon tuteur d'alternance, Monsieur Amir Achache, pour la confiance renouvelee qu'il m'a accordee cette annee. Alors que ma premiere annee avait ete consacree a l'apprentissage aux cotes des consultants seniors, cette annee m'a permis de prendre en charge des parties entieres de missions, toujours sous sa supervision sur les points les plus sensibles, et meme d'aider une nouvelle alternante a ses debuts. Cette confiance, qui n'a cesse de grandir, a ete le moteur principal de ma progression, et je mesure la chance que j'ai eue d'etre accompagne avec autant de patience sur des sujets ou je debutais.

Je souhaite egalement remercier Amine, avec qui j'ai continue a collaborer etroitement sur plusieurs dossiers techniques, et dont l'experience m'a ete precieuse a de nombreuses reprises lorsque je me suis retrouve bloque sur un point technique. Je remercie aussi Nawel, la nouvelle alternante du pole IT-Cybersecurite que j'ai eu la chance d'accompagner sur ses premiers pas, comme mes aines avaient pu le faire pour moi un an plus tot : nos echanges m'ont oblige a reformuler ce que je croyais avoir compris, et c'est souvent en cherchant a lui expliquer une notion simplement que j'ai realise que je la maitrisais moins bien que je ne le pensais.

Je remercie egalement l'ensemble des equipes commerciales et administratives d'AccessPointCompany, en particulier Walid Hamza et Aristide Jeremy, pour leur disponibilite constante et pour m'avoir permis de mieux comprendre le fonctionnement global de l'entreprise au-dela de mon seul perimetre technique. Merci enfin a nos clients, qui m'ont fait confiance sur des missions toujours plus engageantes, et qui ont accepte, avec beaucoup de bienveillance, d'etre accompagnes par un alternant encore en apprentissage sur certains sujets.

Enfin, je remercie mon tuteur academique pour son suivi tout au long de ce cycle ingenieur, et pour les echanges qui m'ont aide a construire un projet professionnel aujourd'hui plus precis qu'il ne l'etait il y a un an. Ce memoire est aussi, en un sens, le fruit de ce dialogue entre le monde academique et le monde professionnel que l'alternance m'aura permis de vivre pendant deux ans.

Resume

En tant qu'étudiant en 5eme et dernière année du cycle ingénieur, spécialité Cybersecurite et Réseaux à l'ESILV, j'ai poursuivi mon alternance au sein d'AccessPointCompany pour une seconde année. Si ma quatrième année avait été celle de la découverte du métier de consultant en cybersecurite operationnelle, cette cinquième année a été celle d'une autonomie grandissante sur des tâches bien delimitées, toujours accompagnée du regard de mon tuteur sur les sujets les plus engageants, et d'une première ouverture vers la gouvernance, les risques et la conformité (GRC).

J'ai continué à réaliser des audits de vulnérabilité et des plans de continuité d'activité, avec un périmètre de responsabilité élargi par rapport à ma première année, et j'ai eu la chance de contribuer, aux côtés de mon tuteur, à un projet particulier : la démarche de certification ISO 27001 qu'AccessPointCompany a engagée pour elle-même. Cette mission m'a fait toucher du doigt les enjeux de crédibilité d'une entreprise de cybersecurite qui doit d'abord être exemplaire avant de conseiller ses clients.

J'ai également élargi mon périmètre technique : participation, en binôme avec un consultant, à des tests d'intrusion, contribution à la mise en place d'un dispositif simple de supervision de securite, implication dans l'analyse d'un incident de securite chez un client, construction d'une première cartographie des risques fournisseurs, et conception d'une campagne de sensibilisation mesurée auprès de plus de deux cents utilisateurs, le tout dans un contexte européen marqué par l'entrée en application de textes comme NIS2 et DORA.

Cette année a également été marquée par un début de transmission : j'ai pu accompagner l'intégration d'une nouvelle alternante au sein du pôle IT-Cybersecurite sur ses premières tâches, en partageant avec elle ce que j'avais moi-même appris un an plus tôt. Expliquer une méthode à quelqu'un qui la découvre m'a beaucoup appris sur ma propre compréhension du métier, et m'a montré à quel point il restait encore des zones grises dans ce que je pensais maîtriser.

Enfin, cette expérience a confirmé et précisé mon projet professionnel : je souhaite aujourd'hui évoluer vers un métier à l'intersection de la technique et de la gouvernance, où l'expertise en securite des systèmes d'information se met au service de la stratégie et de la résilience des organisations. Je termine ce cycle ingénieur avec la conviction qu'un bon consultant en cybersecurite n'est pas seulement celui qui trouve les failles, mais celui qui sait construire, avec les organisations qu'il accompagne, une culture de la securite durable – et je mesure qu'il me reste encore beaucoup à apprendre pour y parvenir pleinement.

Introduction

Ce memoire cloture mon cycle ingenieur a l'ESILV et vient prolonger le rapport que j'avais redige a l'issue de ma quatrieme annee. A l'epoque, je decouvrais le metier de consultant en cybersecurite operationnelle : j'accompagnais les consultants seniors sur le terrain, je m'appropriais les referentiels normatifs et je mesurais, pour la premiere fois, la dimension humaine des enjeux de securite des systemes d'information. Cette cinquieme annee ne repart pas de zero : elle s'inscrit dans la continuite directe de cette premiere immersion, avec une difference notable, celle d'un niveau d'exigence et de responsabilite plus eleve, sans pour autant que je considere avoir atteint une pleine autonomie sur l'ensemble des sujets que j'ai pu aborder.

Pour construire ce memoire, je me suis appuye sur un journal de bord tenu tout au long de l'annee, sur les comptes rendus de mes missions et sur des echanges reguliers avec mon tuteur d'alternance, qui m'a aide a prendre du recul sur ma propre progression. J'ai egalement sollicite les retours de Nawel et d'Amine, mes collegues alternants, dont le regard sur mon evolution complete utilement le mien.

La problematique qui traverse ce memoire est la suivante : *comment un alternant, encore junior a l'entree de cette seconde annee, peut-il progressivement gagner en autonomie sur des missions de cybersecurite a responsabilite croissante, tout en continuant a apprendre au contact de son equipe et en commençant lui-meme a transmettre ce qu'il sait ?* Cette question n'est pas seulement personnelle : elle rejoint un enjeu plus large du secteur de la cybersecurite, confronte a une penurie de talents qui oblige les entreprises comme AccessPointCompany a former rapidement, mais serieusement, de jeunes profils.

Pour y repondre, ce memoire est organise en cinq parties. La premiere partie etudie le positionnement de mon alternance : le secteur economique de la cybersecurite dans lequel elle s'est deroulee, l'engagement de ce secteur en matiere de developpement durable et de responsabilite societale, le cadre reglementaire qui le structure, et la maniere dont AccessPointCompany, puis moi-meme, nous positionnons au sein de cet ecosysteme. La deuxieme partie presente mon alternance : les objectifs qui m'ont ete fixes, le plan de route suivi sur l'annee, les methodes et les outils mobilises, et les equipes avec lesquelles j'ai collabore. La troisieme partie retrace le deroulement concret de mon annee, mission par mission, en detailant la mise en œuvre des outils et methodes choisies ainsi que les difficultes techniques rencontrees. La quatrieme partie prend la forme d'une demarche scientifique et de recherche a part entiere : je m'y appuie sur l'une des difficultes techniques rencontrees en mission – le volume de faux positifs d'un dispositif de supervision de securite – pour la traiter avec un etat de l'art, un protocole experimental et une discussion critique de mes resultats. Enfin, la cinquieme partie dresse le bilan de cette annee ecoulee : les competences developpees et celles qui me manquent encore, le lien avec ma majeure, les difficultes organisationnelles et humaines rencontrees, mes reussites et mes axes d'amelioration, et le plan de carriere que je me suis fixe pour la suite.

Note sur la confidentialite

Conformement aux engagements de confidentialite d'AccessPointCompany envers ses clients, les missions decrites dans ce memoire sont presentees de maniere anonymisee : les noms des

clients ne sont jamais mentionnés, seuls leur secteur d'activité et leur taille approximative sont précisés lorsque cela est nécessaire à la compréhension du contexte. Les chiffres et résultats présentés, notamment ceux issus de la campagne de sensibilisation ou des audits réalisés, sont réels mais ont été vérifiés avec mon tuteur avant intégration à ce document, afin de m'assurer qu'aucune information sensible pour nos clients ou pour AccessPointCompany n'y figure.

1. Positionnement de mon alternance et problematique

Etude du secteur economique de la cybersecurite

Le secteur de la cybersecurite, dans lequel s'est deroulee mon alternance, est un marche en croissance continue depuis plusieurs annees, porte par la multiplication des cybermenaces, par la digitalisation accrue des entreprises et par le renforcement constant des exigences reglementaires. C'est un secteur que j'ai pu observer non seulement depuis mon poste d'alternant chez AccessPointCompany, mais aussi a travers les echanges avec nos clients, nos partenaires et les intervenants professionnels que j'ai pu croiser lors de conferences et de webinaires suivis en parallele de mon activite.

Panorama des acteurs

Ce secteur reunit des acteurs de natures tres differentes, que j'ai appris a mieux distinguer au fil de mes deux annees d'alternance. On y trouve d'abord de grands groupes integres, comme Thales, Orange Cyberdefense ou Capgemini, capables de deployer des offres completes a l'echelle internationale. On y trouve ensuite des editeurs de solutions techniques, qui developpent et commercialisent les outils utilises par les consultants : solutions de SIEM (Security Information and Event Management), d'EDR (Endpoint Detection and Response), ou encore de pare-feux nouvelle generation. Le secteur s'appuie egalement sur des organismes institutionnels qui fixent le cadre : l'ANSSI en France, l'ENISA au niveau europeen, ou la CNIL sur le volet specifique des donnees personnelles. Enfin, une multitude d'ESN (entreprises de services numeriques) et de cabinets de conseil de taille intermediaire occupent le terrain du conseil operationnel et de l'accompagnement de proximite : c'est dans cette derniere categorie que se situe AccessPointCompany.

Produits et services du secteur

Les produits et services de ce secteur couvrent un spectre large, que j'ai eu l'occasion de parcourir en partie durant mon alternance : l'audit et le test d'intrusion, qui visent a identifier des vulnerabilites avant qu'un attaquant ne le fasse ; le conseil en gouvernance et en gestion des risques, qui aide les organisations a structurer leur strategie de securite ; l'integration de solutions techniques, comme les pare-feux ou les outils de chiffrement ; la supervision, qui consiste a surveiller en continu l'activite d'un systeme d'information pour detecter des comportements suspects ; et enfin la formation et la sensibilisation, qui visent a reduire le risque lie a l'erreur humaine.

Grandes orientations et tendances

Plusieurs grandes orientations traversent aujourd'hui ce secteur. La generalisation de l'intelligence artificielle en est une, avec un double visage : elle est a la fois un nouvel outil de defense, capable de detecter des anomalies dans de grands volumes de donnees, et un nouvel outil entre les mains des attaquants, qui l'utilisent pour generer des campagnes de phishing plus credibles ou pour automatiser certaines etapes d'une attaque. La penurie de talents qualifies constitue une seconde tendance de fond, qui pousse les acteurs du secteur, dont AccessPointCompany,

a investir massivement dans la formation de jeunes profils comme les alternants, plutôt que d'attendre des profils déjà expérimentés qui se font rares sur le marché. Enfin, la montée en puissance de la cyberassurance et le durcissement continu du cadre réglementaire poussent de plus en plus d'entreprises, même les plus petites, à s'intéresser sérieusement à leur niveau de sécurité, alors qu'elles n'y accordaient auparavant que peu d'attention.

Quelques ordres de grandeur

Pour situer ces tendances, il m'a semble utile de rassembler quelques ordres de grandeur souvent cités dans la presse professionnelle et lors des webinaires que j'ai pu suivre cette année. Ces chiffres n'ont pas de valeur scientifique précise dans le cadre de ce mémoire, mais ils donnent une idée du contexte dans lequel évolue AccessPointCompany.

Indicateur	Ordre de grandeur
Entreprises françaises ayant subi au moins une tentative de cyberattaque en 2021 (donnée déjà citée dans mon rapport de 4e année)	Pres de 8 sur 10
Part des incidents de sécurité liés, au moins partiellement, à une erreur humaine, d'après mon expérience de terrain chez AccessPointCompany	Grande majorité des cas traités
Réduction du taux de clic sur emails simulés après une session de sensibilisation ciblée, mesurée sur ma campagne de la mission 7	De 34 % à 9 %
Postes vacants dans la cybersécurité en France, d'après les échanges avec le pôle commercial d'AccessPointCompany	Plusieurs milliers, selon les estimations du secteur

Au-delà de leur caractère illustratif, ces chiffres résument assez bien ce que j'ai pu observer sur le terrain cette année : une menace qui touche presque toutes les organisations, une cause humaine prépondérante, une sensibilisation qui fonctionne lorsqu'elle est bien menée, et un marché de l'emploi qui reste très favorable aux jeunes profils comme le mien.

Engagement DD-RSE du secteur de la cybersécurité

L'engagement en matière de développement durable et de responsabilité sociétale (DD-RSE) du secteur de la cybersécurité se décline sur plusieurs volets, que j'ai pu observer à des degrés divers au cours de mon alternance.

Volet social

Sur le plan social, le secteur souffre d'un manque criant de diversité : les femmes restent largement minoritaires parmi les experts techniques, une réalité que j'ai pu constater directement au sein même de mon équipe avant l'arrivée de Nawel. De nombreuses initiatives, portées par des associations professionnelles, des programmes de mentorat et des partenariats avec des écoles, tentent d'y remédier, même si les résultats restent encore limités à l'échelle du secteur. Le secteur porte également une mission d'intérêt général via la sensibilisation du grand public et des PME les moins bien armées face aux cybermenaces, une mission à laquelle j'ai

modestement contribue cette année à travers plusieurs actions de sensibilisation auprès de nos clients.

Volet environnemental

Sur le plan environnemental, le paradoxe est plus délicat à résoudre. La sécurisation des systèmes d'information pousse souvent à la multiplication des outils, des serveurs de journalisation et des équipements redondants, ce qui va à l'encontre d'une logique de sobriété numérique. J'ai pu observer ce paradoxe directement lors de la mise en place d'un dispositif de supervision de sécurité pour un client : chaque nouvelle source de journalisation ajoutée améliore la visibilité sur les menaces, mais augmente également la consommation de stockage et de calcul nécessaire pour les traiter. Certains acteurs du secteur commencent néanmoins à intégrer des critères d'efficacité énergétique dans le choix de leurs infrastructures, une réflexion encore balbutiante chez AccessPointCompany mais que j'ai pu voir émerger dans les discussions internes.

Volet gouvernance

Sur le plan de la gouvernance, enfin, la protection des données personnelles, encadrée par le RGPD, et l'éthique de la pratique du test d'intrusion, encadrée par un cadre légal strict et par des chartes déontologiques, constituent le cœur même de l'engagement RSE du secteur. C'est un volet que j'ai particulièrement mesuré cette année en participant, en binôme, à des tests d'intrusion : chaque action devait être explicitement autorisée par le client, documentée, et menée dans le strict respect du périmètre défini à l'avance.

L'engagement d'AccessPointCompany

AccessPointCompany, à son échelle de PME, traduit cet engagement par des actions concrètes : une charte éthique signée par chaque consultant avant toute mission de test d'intrusion, un investissement récurrent dans la formation de jeunes alternants comme moi et comme Nawel, et depuis cette année, sa propre démarche de certification ISO 27001, qui l'engage à appliquer à elle-même les exigences de gouvernance qu'elle recommande à ses clients. Cette cohérence entre le discours tenu aux clients et les pratiques internes de l'entreprise m'a semblé être un élément important de sa crédibilité sur le marché.

Cadre réglementaire et normatif

Le cadre réglementaire dans lequel évolue AccessPointCompany, et donc dans lequel s'est déroulée mon alternance, s'est encore renforcé cette année. Trois textes ont particulièrement structuré mes missions.

La directive NIS2

La directive européenne NIS2 (Network and Information Security 2) étend considérablement le périmètre d'entreprises soumises à des obligations de cybersécurité, en intégrant de nombreux secteurs jusque-là peu concernés par une réglementation spécifique. Pour AccessPointCompany, cela s'est traduit par un afflux de demandes de clients jusque-là peu sensibilisés, désormais contraints par la loi de structurer leur sécurité, et qui sont venus nous solliciter pour des audits

de mise en conformite.

Le reglement DORA

Le reglement DORA (Digital Operational Resilience Act) impose au secteur financier des exigences renforcees en matiere de resilience operationnelle numerique, avec des objectifs precis de temps de reprise (RTO) et de perte de donnees maximale tolerable (RPO). J'ai directement mesure l'impact de ce texte cette annee en travaillant sur des dossiers de continuite d'activite pour des clients du secteur bancaire, ou le niveau d'exigence etait sensiblement plus eleve que sur mes dossiers de premiere annee.

Le RGPD

Le RGPD, deja bien connu depuis plusieurs annees, reste neanmoins une reference constante dans l'ensemble de nos missions : chaque cartographie des systemes d'information que je realise integre desormais systematiquement une reflexion sur les traitements de donnees personnelles concernees, meme lorsque ce n'est pas l'objet principal de la mission.

Cette accumulation d'obligations reglementaires n'est pas sans consequence sur le quotidien d'un consultant junior comme moi : il faut savoir naviguer entre plusieurs referentiels, parfois avec des exigences qui se recoupent partiellement, et savoir orienter le client vers le bon niveau de priorite sans le noyer sous une complexite reglementaire qu'il ne maitrise pas toujours.

Positionnement d'AccessPointCompany au sein de son secteur d'activite

Un an apres ma premiere presentation de l'entreprise, AccessPointCompany (APC Digital) a poursuivi sa transformation. Toujours basee a Cachan en Ile-de-France, avec son antenne a Alger, l'entreprise a renforce ses effectifs au sein du pole IT-Cybersecurite et a engage sa propre demarche de certification ISO 27001, un signal fort envoye a ses clients comme a ses partenaires. Sur son marche, AccessPointCompany se differencie par une approche de proximite, moins standardisee que celle des grands cabinets : chaque mission est adaptee au contexte specifique du client, avec une preference marquee pour des livrables operationnels plutot que pour des rapports theoriques de plusieurs centaines de pages.

Le catalogue de services s'est etoffe autour de quatre grands axes desormais bien identifies : le diagnostic (audits et tests d'intrusion), la resilience (plans de continuite et de reprise d'activite), la conformite (accompagnement reglementaire) et, nouveaute de cette annee, une premiere brique de supervision (monitoring de securite simplifie pour les clients ne disposant pas de SOC en interne). Sur ses segments de marche, l'entreprise cible principalement les PME et ETI, avec une clientele qui s'est elargie cette annee vers des comptes du secteur bancaire et assurantiel, plus exigeants du fait de DORA, ainsi que vers des operateurs de telecommunications en Algerie.

Pour mieux situer AccessPointCompany face a la concurrence, j'ai construit, avec l'aide de mon tuteur, une analyse synthetique de ses forces et faiblesses :

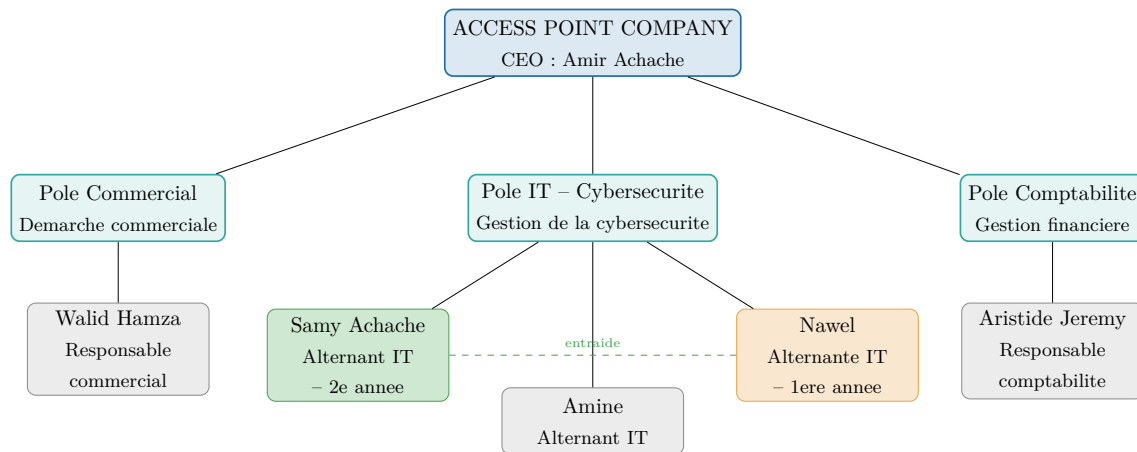
Forces	Faiblesses
Approche de proximite, forte personnalisation des livrables.	Taille reduite face aux grands cabinets sur les appels d'offres les plus importants.
Presence internationale (France, Algerie, clients au Moyen-Orient).	Offre de supervision encore jeune et peu automatisee.
Culture de la formation des jeunes alternants.	Dependance a quelques consultants seniors sur les dossiers les plus complexes.
Opportunites	Menaces
Durcissement reglementaire (NIS2, DORA) generant de nouveaux besoins clients.	Concurrence croissante des grands groupes sur le segment PME/ETI.
Credibilite renforcee par la certification ISO 27001 interne en cours.	Penurie de talents qualifies, difficulte a recruter aussi vite que la demande.

Perspectives d'évolution pour AccessPointCompany

En échangeant avec mon tuteur sur les perspectives de l'entreprise, plusieurs pistes d'évolution se dessinent pour les prochaines années. La première est la consolidation de l'offre de supervision de sécurité, encore jeune, qui pourrait devenir un relais de croissance important si l'entreprise parvient à l'automatiser davantage sans perdre l'approche de proximité qui la caractérise. La seconde est la poursuite du développement à l'international, notamment autour du dossier avec l'opérateur Algérie Telecom auquel j'ai pu ponctuellement contribuer, qui pourrait ouvrir la voie à d'autres clients de ce type dans la région. La troisième, enfin, est la valorisation commerciale de la certification ISO 27001 interne, une fois obtenue, comme argument de différenciation face à des concurrents de taille plus importante mais moins agiles sur ce type de démarche.

Role de mon alternance et mon positionnement au sein de l'entreprise

J'ai réalisé ma seconde année d'alternance au sein du département IT-Cybersecrète d'AccessPointCompany, une équipe composée de consultants aux profils variés et complémentaires. Mon positionnement a évolué par rapport à ma première année : je ne suis plus uniquement en observation ou en exécution encadrée, mais je prends désormais en charge des parties significatives de missions, tout en restant épaulé par mon tuteur dès que la situation devient sensible ou stratégique – restitution devant un COMEX, arbitrage sur une remédiation critique, ou relation avec un client important.



Concretement, mon role est reste celui d'un alternant, mais avec un niveau d'exigence et de responsabilite plus eleve qu'en premiere annee : cadrage d'une partie des missions avec le client sous supervision, realisation technique en autonomie ou en binome selon la complexite du sujet, redaction de livrables desormais relus mais moins systematiquement corriges par mon tuteur. Une semaine type se compose generalement de deux a trois demi-journees consacrees a un audit ou a un dossier en cours, d'un temps dedie au projet de certification ISO 27001 interne, d'un point hebdomadaire avec mon tuteur, et de moments plus informels d'echange avec Nawel ou Amine sur des questions techniques. J'ai egalement pu, pour la premiere fois, partager mon experience avec Nawel, la nouvelle alternante arrivee cette annee, sur des sujets simples ou je me sentais legitime.

Temoignage – Nawel, alternante IT-Cybersecurite

"Samy a ete l'une des premieres personnes a qui j'ai pose mes questions les plus basiques sans avoir peur d'avoir l'air idiote. Il m'a explique la methode EBIOS avec ses propres mots, pas avec ceux du referentiel, et ca m'a beaucoup aidee a demarrer."

Comparaison avec ma premiere annee d'alternance

Pour mieux mesurer mon evolution, il m'a semble utile de comparer directement mon positionnement de premiere annee avec celui de cette seconde annee, sur quelques dimensions cles de mon activite.

Dimension	4e annee (premiere annee)	5e annee (seconde annee)
Cadrage client	Observation aux cotes d'un consultant senior	Cadrage seul sur les dossiers simples, accompagne sur les autres
Realisation technique	Execution encadree, pas a pas	Autonomie sur les taches maitrisees, binome sur les taches nouvelles
Redaction de livrables	Systematiquement corrigees avant envoi	Relue mais moins souvent corrigees en profondeur
Relation aux pairs	Accompagne par des alternants plus experimentes	Debut d'accompagnement d'une alternante plus junior
Perimetre thematique	Audits, PCA	Audits, PCA, pentest, supervision, GRC, risques fournisseurs

Cette comparaison met en evidence une progression reelle, mais qui reste, sur plusieurs dimensions, une progression de degre plutot que de nature : je n'ai pas change de statut, je continue d'etre un alternant epaule par son equipe, mais le niveau de complexite des sujets que l'on me confie desormais, et la part d'autonomie qui m'est accordee sur les sujets deja maitrises, ont sensiblement augmente.

2. Presentation de mon alternance

Objectifs de mes missions en apprentissage et projets confies

En debut d'annee, mon tuteur et moi avons defini ensemble trois grands types d'objectifs pour cette seconde annee d'alternance.

Les objectifs techniques, d'abord : gagner en autonomie sur les missions deja maitrisees l'annee precedente – audits de vulnerabilite, plans de continuite d'activite – en reduisant progressivement le niveau de supervision directe sur le terrain, tout en elargissant mon perimetre vers des sujets nouveaux pour moi, comme la participation active a des tests d'intrusion, une premiere approche de la supervision de securite, et une decouverte de l'analyse post-incident.

Les objectifs transverses et humains, ensuite : ameliorer ma capacite a communiquer des resultats techniques a des interlocuteurs non techniques, apprendre a gerer plusieurs dossiers en parallele sans perdre en qualite, et commencer a transmettre mes acquis a une collegue plus junior que moi.

Les objectifs personnels, enfin : commencer a explorer la dimension gouvernance, risques et conformite (GRC) du metier, un axe qui m'interessait de plus en plus depuis ma premiere annee, en participant a la demarche de certification ISO 27001 qu'AccessPointCompany a engagee pour elle-meme.

Objectif	Projet confie associe
Gagner en autonomie sur les missions maitrisees	Audits de vulnerabilite en responsabilite elargie pour plusieurs clients PME
Elargir le perimetre technique	Tests d'intrusion en binome, premiere approche de la supervision de securite
Explorer la dimension GRC	Contribution au projet de certification ISO 27001 interne
Ameliorer la communication et la transmission	Restitutions clients, accompagnement de Nawel

Plan de route

Pour organiser mon annee, j'ai construit avec mon tuteur un retroplanning, revu regulierement au fil des priorites commerciales de l'entreprise et des alea propres a chaque mission.

Periode	Jalon
Septembre	Reprise de contact avec l'equipe, point de cadrage avec mon tuteur sur les objectifs de l'annee, reprise des missions courantes (audits, PCA).
Octobre	Integration et accompagnement des premieres semaines de Nawel au sein du pole ; poursuite des audits en cours.
Novembre	Lancement de la contribution au projet de certification ISO 27001 interne : premier inventaire des actifs.
Decembre	Poursuite de l'analyse de risques EBIOS sur le projet ISO 27001 interne ; premiere participation a un test d'intrusion en binome.

Periode	Jalon
Janvier	Redaction d'une premiere version de la declaration d'applicabilite (SoA) du projet ISO 27001 interne.
Fevrier	Conception de la campagne de simulation de phishing pour un client ; deuxieme participation a un test d'intrusion.
Mars	Implication dans l'analyse d'un incident de securite chez un client.
Avril	Contribution a la mise en place d'un dispositif simple de supervision de securite ; construction de la cartographie des risques fournisseurs.
Mai	Restitutions clients sur les principales missions de l'annee ; finalisation des livrables du projet ISO 27001 interne.
Juin	Bilan de l'annee avec mon tuteur, redaction du present memoire.

Analyse des besoins

L'analyse de besoins pour chaque mission a suivi la meme logique qu'en premiere annee, avec un niveau de responsabilite different. Chaque mission commence par un rendez-vous de cadrage avec le client, souvent accompagne de mon tuteur ou d'un consultant senior sur les dossiers les plus complexes, mais que j'ai pu mener seul sur certains dossiers plus simples. L'objectif de ce rendez-vous est de comprendre le contexte metier avant de se pencher sur les aspects techniques : quelle est l'activite du client, quelles sont ses contraintes de disponibilite, quels sont ses enjeux reglementaires specifiques, et qui sont les interlocuteurs a impliquer.

Sur le projet de certification ISO 27001 interne, cette etape a pris une forme particuliere : il ne s'agissait plus d'interroger un client externe, mais de recueillir les besoins et les contraintes de mes propres collegues, ce qui m'a demande une posture differente, plus proche de l'ecoute interne que du questionnement client classique.

Methodes et outils utilises

Sur le plan des referentiels normatifs, j'ai continue a m'appuyer sur les normes ISO 27001 (management de la securite de l'information) et ISO 22301 (continuite d'activite), ainsi que sur la methode EBIOS Risk Manager pour la gestion des risques. J'ai egalement du me familiariser plus serieusement avec le contenu des textes NIS2 et DORA, dont je ne connaissais l'annee precedente que les grandes lignes.

Sur le plan des outils techniques, j'ai utilise Nessus pour les scans de vulnerabilite automatisees, nmap pour la reconnaissance reseau, Burp Suite lors des tests d'intrusion sur des applications web, et John the Ripper pour des exercices de sensibilisation a la robustesse des mots de passe. Pour la restitution des resultats, j'ai continue a utiliser des tableaux de bord simples sous Excel, et j'ai decouvert cette annee un outil de visualisation plus avance pour presenter certains indicateurs a nos clients.

Sur le plan de la gestion de projet et de la communication, j'ai utilise un tableau de suivi partage pour organiser mes differents dossiers en parallele, et j'ai participe a des points reguliers, en presentiel comme a distance, avec les equipes clientes et avec mon tuteur.

Equipes concernees

Mes missions m'ont amene a collaborer avec des equipes variees. En interne, j'ai travaille principalement avec le pole IT-Cybersecurite, mais aussi ponctuellement avec le pole commercial lors de rendez-vous avant-vente ou ma presence permettait d'apporter un premier eclairage technique. Cote client, j'ai ete en contact aussi bien avec des equipes IT operationnelles, plus a l'aise avec le vocabulaire technique, qu'avec des directions metier ou des directions generales, avec lesquelles j'ai du adapter mon discours. Sur le projet ISO 27001 interne, la liste des parties prenantes incluait, fait nouveau pour moi, la direction generale d'AccessPointCompany elle-meme.

Exemple d'une semaine type

Pour rendre plus concret le fonctionnement de mon annee, voici un exemple de semaine type, tel que je le notais dans mon journal de bord vers le mois de fevrier, au moment ou plusieurs de mes missions se recoupaient.

Jour	Activites principales
Lundi	Point hebdomadaire avec mon tuteur ; poursuite de l'audit de vulnerabilite en cours chez un client PME.
Mardi	Journee consacree au projet ISO 27001 interne : relecture des retours de mon tuteur sur la SoA, corrections.
Mercredi	Test d'intrusion en binome avec un consultant sur une application web cliente (matinee) ; redaction du compte rendu (apres-midi).
Jeudi	Echange avec Nawel sur la methode EBIOS ; preparation de la campagne de simulation de phishing avec un consultant.
Vendredi	Veille technologique ; mise a jour de mes dossiers en cours dans le tableau de suivi partage ; temps de recul et de prise de notes pour ce memoire.

Cette semaine illustre bien la nature de mon activite cette annee : plusieurs dossiers menes en parallele, une alternance entre travail autonome et travail en binome selon la nature du sujet, et des moments reguliers d'echange, que ce soit avec mon tuteur ou avec Nawel.

3. Deroulement de mon alternance

Presentation des differentes missions

Mission 1 – Audits de vulnerabilite en autonomie accrue

J'ai poursuivi la realisation d'audits de vulnerabilite pour des clients PME, en suivant les normes ISO 27001 et ISO 22301 comme cadre methodologique. Par rapport a ma premiere annee, j'ai gagne en autonomie sur l'interpretation des resultats et sur la premiere priorisation des remediations, meme si la validation finale des recommandations les plus sensibles est restee du ressort de mon tuteur. Sur l'un de ces audits, chez un client du secteur de la logistique, j'ai identifie un serveur de test expose sur le reseau interne sans authentication renforcee, un cas assez proche de ce que j'avais deja pu observer lors de ma premiere annee, mais que j'ai cette fois-ci pu documenter et presenter au client de maniere entierement autonome, avant relecture de mon tuteur.

Mission 2 – Contribution au projet de certification ISO 27001 interne

La mission la plus formatrice de mon annee a ete ma contribution, sous la responsabilite directe de mon tuteur, au projet de certification ISO 27001 d'AccessPointCompany elle-meme. J'ai participe a l'inventaire des actifs de l'entreprise – postes de travail des consultants, acces aux outils clients, documentation des audits realises – puis a l'analyse de risques selon la methode EBIOS, en construisant des scenarios comme *"un consultant quitte l'entreprise avec les identifiants d'accès clients"* ou *"un poste de travail compromis expose les rapports d'audit confidentiels de nos clients"*. J'ai ensuite redige une premiere version de plusieurs sections de la declaration d'applicabilite (Statement of Applicability), un document qui recense, pour chacune des mesures de l'Annexe A de la norme, si elle est retenue et pourquoi. Cette premiere version a ete revue et largement corrgee par mon tuteur avant validation, ce qui m'a permis de mesurer l'ecart entre ma comprehension theorique de la norme et son application rigoureuse.

Parmi les mesures de l'Annexe A que j'ai eu a documenter, trois m'ont particulierement marque. La mesure relative au controle des acces m'a demande de retracer, avec l'aide de mon tuteur, qui avait acces a quoi au sein de l'entreprise, un exercice plus complexe que prevu tant les acces s'etaient accumules au fil des annees sans revue systematique. La mesure relative a la gestion des incidents de securite m'a permis de reutiliser, dans un contexte interne cette fois, les reflexes acquis lors de la mission 4 decrite plus loin. Enfin, la mesure relative a la sensibilisation du personnel a ete l'occasion d'un echange interessant avec mon tuteur sur la difficulte, pour une entreprise de cyberscurite, de former ses propres consultants sans tomber dans un discours trop evident pour des experts du sujet.

Ce que ce projet m'a appris

Etre implique dans l'audit de sa propre entreprise est un exercice plus inconfortable qu'on ne l'imagine, meme lorsqu'on n'en est pas le pilote. J'ai appris a documenter des ecarts qui me concernaient directement, et a accepter les remarques de mon tuteur sur des livrables que je pensais aboutis.

Mission 3 – Tests d'intrusion en binome

J'ai participe, toujours en binome avec un consultant plus experimente, a plusieurs tests d'intrusion sur des applications web exposees. Mon role a evolue par rapport a ma premiere annee, ou j'etais essentiellement observateur : cette annee, j'ai pu operer moi-meme certaines etapes de la reconnaissance et des tests, sous la supervision directe du consultant qui validait chaque action avant qu'elle ne soit menee.

Chaque test suivait le meme deroulement en trois temps, que j'ai commence a interioriser sans encore le maitriser pleinement. La premiere etape, la reconnaissance, consistait a cartographier la surface d'attaque de l'application : pages accessibles, formulaires, parametres d'URL, technologies utilisees, a l'aide d'outils comme nmap pour le reseau et de l'exploration manuelle du site pour la partie applicative. C'est sur cette etape que le consultant m'a laisse le plus de latitude, en verifiant simplement mes conclusions a la fin de chaque session. La deuxieme etape, les tests a proprement parler, se faisait avec Burp Suite pour intercepter et modifier les requetes envoyees au serveur ; c'est la que la supervision du consultant etait la plus etroite, chaque tentative devant etre validee avant d'etre executee, en particulier lorsqu'elle touchait a des mecanismes d'authentification. La troisieme etape, la restitution, consistait a documenter chaque faille trouvee avec son niveau de criticite, un scenario d'exploitation et une recommandation de correction.

Sur l'un de ces tests, mene pour un client disposant d'un espace client en ligne, j'ai repere qu'un des champs du formulaire de connexion ne filtrait pas correctement les caracteres speciaux. Avec l'accord et sous le regard du consultant, j'ai teste une injection simple qui a permis de contourner l'ecran d'authentification sans connaitre de mot de passe valide. Cette decouverte m'a beaucoup marque, tant la faille etait simple a exploiter une fois identifiee, mais aussi parce qu'elle m'a montre a quel point il est facile, en tant que developpeur, de laisser passer ce genre d'erreur sans un regard exterieur. Je suis reste conscient, tout au long de cette mission, que je n'aurais pas su mener seul l'ensemble du test : c'est le consultant qui a decide du perimetre exact, valide chaque etape sensible et redige la synthese finale presentee au client, moi me concentrant sur la partie reconnaissance et sur la documentation des resultats.

Mission 4 – Analyse d'un incident de securite

J'ai ete implique dans l'analyse d'un incident de securite chez un client, une attaque par rancongiel ayant partiellement abouti. Sous la conduite d'un consultant senior, j'ai participe a la reconstruction d'une chronologie simplifiee de l'attaque et a l'identification du vecteur d'entree probable – un acces distant mal segmente. Cette mission m'a permis de decouvrir une dimension du metier que je ne connaissais pas encore : la gestion, dans l'urgence, d'un client en situation de crise, avec des interlocuteurs stressés et des decisions a prendre rapidement, souvent avec des informations incompletes.

Mission 5 – Premiere approche de la supervision de securite

J'ai contribue a la mise en place d'un dispositif simple de supervision de securite pour un client de taille intermediaire, sous la responsabilite d'un consultant experimente sur ce sujet encore nouveau pour moi. La premiere etape a consiste a identifier, avec le client, les sources

de journaux les plus utiles a centraliser : le pare-feu perimetrique, le serveur d'authentification et les postes de travail les plus exposes. J'ai participe a la configuration de la remontee de ces journaux vers un outil de centralisation, en m'occupant principalement de la partie la plus accessible, la remontee des journaux du pare-feu, le consultant prenant en charge les parties plus delicates liees a l'authentification.

Nous avons ensuite defini ensemble une premiere liste de regles d'alerte simples, volontairement peu nombreuses pour rester exploitables par une petite equipe : tentatives de connexion repetees et infructueuses sur un meme compte en moins de cinq minutes, connexions reussies en dehors des horaires habituels du client, et apparition d'un nouveau compte administrateur. J'ai propose une quatrieme regle, portant sur les transferts de fichiers volumineux vers l'exterieur, que le consultant a jugee pertinente mais trop bruyante pour etre activee en l'etat sans un travail de calibrage plus long que le temps dont nous disposions sur cette mission.

Une fois le dispositif en place, j'ai participe au suivi des premieres alertes remonte'es sur une periode de quelques semaines. La grande majorite d'entre elles se sont revele'es etre des faux positifs – des collaborateurs travaillant occasionnellement en dehors des horaires habituels – ce qui m'a fait prendre conscience de la difficulte a regler correctement ce type de dispositif : trop de regles generent du bruit et finissent par etre ignorees, trop peu de regles laissent passer des signaux faibles. Il s'agissait la d'une premiere decouverte de ce sujet pour moi, avec une contribution encore modeste au regard de la complexite du domaine, et je considere que la supervision de securite reste aujourd'hui l'un des domaines ou j'ai le plus a apprendre, en particulier sur le calibrage fin des regles de detection et sur l'utilisation d'outils de correlation plus avances que celui, volontairement simple, utilise sur cette mission.

Mission 6 – Cartographie des risques fournisseurs

J'ai construit, pour deux clients desormais soumis a des exigences reglementaires renforcees, une premiere cartographie des risques lies a leurs prestataires tiers. Cette mission consistait a recenser les fournisseurs ayant acces au systeme d'information du client, a evaluer leur niveau d'accès et la sensibilite des donnees auxquelles ils pouvaient acceder, puis a construire une matrice de criticite simple permettant de prioriser les fournisseurs a controler en priorite.

J'ai commence par organiser, avec mon interlocuteur cote client, un recensement exhaustif des prestataires externes disposant d'un acces, meme ponctuel, au systeme d'information : editeur du logiciel de comptabilite, societe de maintenance informatique, prestataire d'hebergement, et pour l'un des deux clients, un sous-traitant charge de la gestion de la paie. Pour chaque fournisseur, j'ai envoye un court questionnaire, valide au prealable par mon tuteur, portant sur la nature de leur acces, les mesures de securite qu'ils appliquaient de leur cote et l'existence ou non d'un contrat integrant des clauses de securite. Ce travail de collecte a ete plus long que prevu : plusieurs fournisseurs ont mis plusieurs semaines a repondre, et j'ai du relancer certains d'entre eux avec l'appui du client.

A partir de ces reponses, j'ai construit une matrice croisant le niveau d'accès du fournisseur (lecture seule, ecriture, administration) et la sensibilite des donnees concernees (publique, interne, confidentielle), pour aboutir a un niveau de criticite global – faible, moyen, eleve ou critique – pour chaque prestataire.

Type de fournisseur	Niveau d'accès	Sensibilite des donnees	Criticite
Sous-traitant gestion de la paie	Ecriture	Confidentielle (donnees RH)	Critique
Prestataire de maintenance informatique	Administration	Interne	Eleve
Editeur du logiciel de comptabilite	Ecriture	Interne	Moyen
Prestataire d'hebergement	Lecture seule (logs)	Publique	Faible

Cette matrice a permis de mettre en evidence, pour l'un des deux clients, que le sous-traitant en charge de la paie disposait d'un acces permanent et non limite dans le temps a la base de donnees RH, sans que le contrat qui les liait ne mentionne d'exigence de securite particuliere. J'ai signale ce point a mon tuteur, qui a confirme qu'il s'agissait d'un risque a remonter en priorite au client, et nous avons recommande ensemble la mise en place d'un acces limite dans le temps et la renegotiation du contrat avec une clause de securite minimale. J'ai mene cette mission de maniere largement autonome sur la collecte et la construction de la matrice, avec une relecture de mon tuteur sur les conclusions et les recommandations avant restitution au client.

Mission 7 – Sensibilisation et campagne de simulation de phishing

J'ai participe a la conception d'une campagne de simulation de phishing aupres de plus de deux cents collaborateurs d'un client, avec mesure du taux de clic avant et apres une session de sensibilisation ciblee. Le taux de clic est passe de 34 % avant sensibilisation a 9 % trois mois apres une session ciblee que j'ai coanimee avec un consultant, un resultat qui a convaincu le client d'investir durablement dans la formation de ses equipes plutot que dans le seul outillage technique. Cette mission m'a permis pour la premiere fois de quantifier objectivement l'impact d'une action de sensibilisation, alors que je n'avais, l'annee precedente, que des retours qualitatifs sur ce type d'actions.

Mission 8 – Accompagnement de Nawel et soutien ponctuel au pole commercial

Enfin, j'ai pu accompagner de maniere informelle les premiers pas de Nawel, la nouvelle alternante du pole, en partageant avec elle les methodes que j'avais moi-meme decouvertes un an plus tot, notamment sur la lecture des referentiels ISO et la logique de la methode EBIOS. J'ai egalement ete sollicite a deux reprises par le pole commercial pour apporter un premier eclairage technique lors de rendez-vous avant-vente, notamment sur un dossier avec un operateur de telecommunications algerien, une experience qui m'a fait decouvrir la dimension commerciale du metier de consultant.

Mission 9 – Veille technologique et contribution a la base de connaissances interne

En parallele de mes missions clients, j'ai consacre un temps regulier, meme s'il est reste modeste, a la veille technologique : suivi de bulletins de securite (CERT-FR notamment), lecture d'articles sur les nouvelles familles de rancongiels observees, et suivi des evolutions

reglementaires en cours. J'ai partage certains de ces elements de veille avec le reste de l'equipe lors de points informels, et j'ai commence a alimenter, avec l'accord de mon tuteur, une base de connaissances interne recensant les procedures et modeles de documents que nous utilisons le plus frequemment, un travail encore partiel a la fin de mon alternance mais que je considere utile pour les futurs alternants du pole, dont Nawel a deja pu se servir.

Mise en œuvre des outils et methodes choisies

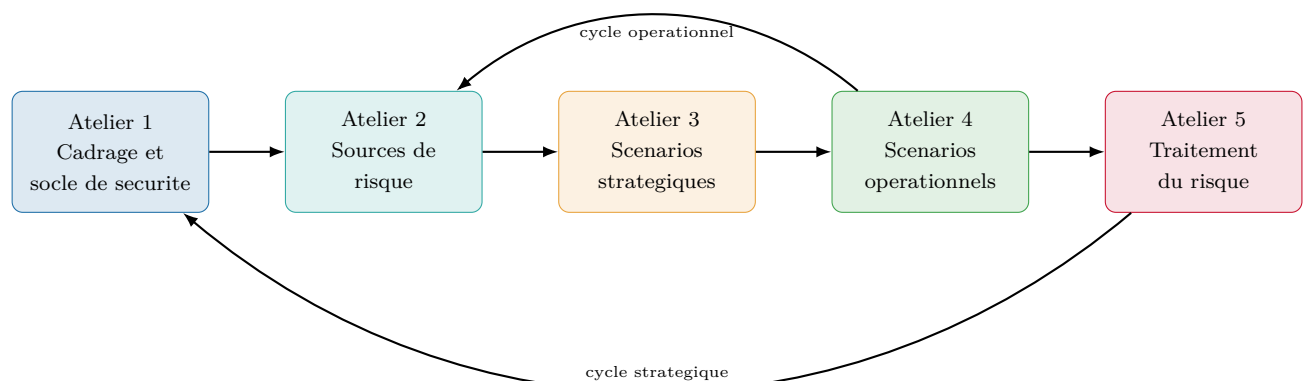
Sur le plan methodologique, j'ai continue a m'appuyer sur les trois piliers – humain, technologie, infrastructure – qui structurent l'approche d'AccessPointCompany.

Pilier humain

Sur le pilier humain, la campagne de simulation de phishing decrite plus haut a ete mon principal terrain d'apprentissage cette annee. Au-dela de la mesure du taux de clic, j'ai participe a la conception des messages simules, en veillant a ce qu'ils restent representatifs de menaces reelles sans etre trop faciles a detecter ni trop trompeurs. J'ai egalement coanime, pour la premiere fois, une session de sensibilisation en presentiel, un exercice qui m'a demande de synthetiser des notions techniques pour un public non specialiste.

Pilier technologique

Sur le pilier technologique, la methode EBIOS a ete mon principal cadre de travail sur le projet ISO 27001 interne, comme illustre ci-dessous. Construire des scenarios de risque realistes sur sa propre organisation a une resonance particuliere lorsque l'on sait que ces scenarios touchent directement son propre quotidien professionnel.



Ma grille de scoring des risques, construite lors de ma premiere annee, a ete enrichie cette annee d'une dimension reglementaire : au-dela du role de l'actif, de la sensibilite des donnees et de sa resistance aux attaques, j'ai propose d'y integrer un quatrieme critere – l'exposition reglementaire de l'actif (DORA, NIS2, RGPD) – proposition que mon tuteur a validee et que nous avons ensuite appliquee ensemble sur plusieurs dossiers clients, dont la cartographie des risques fournisseurs decrite en mission 6.

Pilier infrastructure

Sur le pilier infrastructure, j'ai decouvert les bases de la supervision de securite lors de la mission 5, un sujet sur lequel je debute encore et que je souhaite approfondir. J'ai egalement eu une premiere exposition, tres limitee, a des problematiques de securite des environnements cloud lors d'un audit ou le client hebergeait une partie de son infrastructure chez un fournisseur cloud public : je n'ai pas eu, sur ce point precis, l'autonomie necessaire pour aller au-dela d'un simple constat, et j'ai laisse cette partie du dossier a un consultant plus experimente sur ces sujets.

Difficultes techniques rencontrees durant les missions

Au-dela des difficultes organisationnelles que je developpe dans le bilan de ce memoire, j'ai rencontre plusieurs difficultes proprement techniques cette annee. Sur un audit chez un client disposant d'une infrastructure ancienne, j'ai eu des difficultes a interpreter certains resultats de scan Nessus, qui remontaient de nombreux faux positifs lies a des services legacy mal documentes ; j'ai du, avec l'aide d'Amine, verifier manuellement chaque alerte avant de les integrer a mon rapport, ce qui m'a pris beaucoup plus de temps que prevu mais m'a appris a ne jamais faire confiance aveuglement a un outil automatise.

Sur le projet ISO 27001 interne, la principale difficulte technique a ete de documenter des mesures de securite qui n'existaient, en pratique, que de maniere informelle : par exemple, une procedure de revocation des acces lors du depart d'un consultant existait bien dans les faits, mais n'avait jamais ete formellement ecrite. J'ai du, avec mon tuteur, formaliser cette procedure a partir des pratiques reelles observees, un exercice different de celui auquel j'etais habitue lors d'un audit client classique.

Enfin, lors du test d'intrusion mentionne en mission 3, j'ai rencontre une difficulte lie a l'environnement de test lui-meme : l'application ciblee disposait d'un systeme de protection qui bloquait temporairement les adresses IP generant trop de requetes, ce qui a ralenti nos tests. Le consultant avec qui je travaillais m'a alors montre comment adapter notre rythme de tests pour rester sous ce seuil, une lecon pratique que je n'aurais pas pu acquerir uniquement par la theorie.

Une derniere difficulte technique, plus diffuse, a concerne la mission de supervision de securite (mission 5) : le volume de journaux remontes par les equipements du client etait tel qu'il devenait difficile, avec les moyens simples dont nous disposions, de distinguer un signal pertinent du bruit de fond genere par l'activite normale du systeme. Je n'ai pas trouve, cette annee, de solution pleinement satisfaisante a ce probleme, et je considere que c'est precisement ce type de difficulte qui justifie mon souhait de continuer a me former sur les outils de supervision plus avances, que je n'ai fait qu'entrapercevoir chez AccessPointCompany.

Realisations individuelles et en equipe

Pour etre transparent sur mon niveau reel d'autonomie cette annee, je distingue ci-dessous ce que j'ai realise seul de ce qui a ete fait en equipe.

En autonomie (« je »)	En equipe (« nous »)
Realisation technique complete d'audits de vulnerabilite pour des clients PME, avec validation finale par mon tuteur.	Cadrage des missions les plus complexes avec le client, toujours accompagne de mon tuteur ou d'un consultant senior.
Inventaire des actifs et premiere redaction de la SoA pour le projet ISO 27001 interne.	Analyse de risques EBIOS du projet ISO 27001 interne, menee en atelier avec mon tuteur et un consultant.
Construction de la cartographie des risques fournisseurs, avec relecture finale de mon tuteur.	Tests d'intrusion, realises en binome avec un consultant qui validait chaque etape.
Premiere analyse et mise en forme des resultats de la campagne de simulation de phishing.	Conception des messages simules et animation de la session de sensibilisation, coanimee avec un consultant.
Accompagnement informel de Nawel sur des questions methodologiques simples.	Analyse de l'incident de securite chez un client, sous la conduite d'un consultant senior.
Verification manuelle des faux positifs remontes par les scans automatises.	Mise en place du dispositif de supervision de securite, avec un consultant en charge du projet.

4. Demarche scientifique et recherche : reduire les faux positifs en supervision de securite

Ce chapitre repond a un exercice distinct des trois precedents : il ne s'agit plus de rendre compte de mes missions operationnelles, mais de prendre du recul sur l'une des difficultes techniques que j'y ai rencontrees, en la traitant avec une demarche scientifique structuree – etat de l'art, methode, resultats, discussion critique. J'ai choisi de partir de la difficulte la plus marquante de la mission 5 : la difficulte a distinguer, dans un dispositif de supervision de securite simple, un signal pertinent du bruit genere par l'activite normale d'une petite organisation.

Introduction

Contexte et problematique

Lors de la mission 5 decrite au chapitre precedent, j'ai contribue, avec un consultant, a la mise en place d'un dispositif de supervision de securite fonde sur des regles d'alerte statiques : un seuil de tentatives de connexion echouees, une plage horaire habituelle, une liste de comptes sensibles. Ce type d'approche, tres repandu chez les prestataires de la taille d'AccessPointCompany, presente un defaut que j'ai constate directement sur le terrain : la grande majorite des alertes remonteent etaient des faux positifs, generes par des usages legitimes mais inhabituels – un collaborateur qui se connecte tot un jour de deplacement, par exemple. Ce constat souleve une question plus large que celle de ma seule mission : *quelles methodes de detection d'anomalies pourraient reduire le taux de faux positifs d'un dispositif de supervision de securite, sans en complexifier excessivement l'exploitation par une petite equipe informatique disposant de peu de moyens ?*

Limites des approches actuelles

Les approches a base de regles statiques, comme celle utilisee en mission 5, ont pour elles la simplicite et la transparence : une regle se lit, se comprend et se corrige facilement, meme par un non-expert. Mais elles se heurtent a une limite structurelle bien connue dans la litterature sur la detection d'intrusion : elles ne peuvent capturer que les scenarios explicitement anticipes par celui qui les redige, et elles echouent a distinguer un comportement rare mais legitime d'un comportement rare et malveillant, ce qui explique le volume de faux positifs observe. A l'inverse, les approches plus avancees, fondees sur l'apprentissage automatique, promettent de reduire ce volume en apprenant directement les habitudes normales d'un systeme plutot qu'en les codant a la main, mais elles sont generalement pensees pour des environnements disposant de gros volumes de donnees et d'equipes dediees, ce qui est rarement le cas des clients PME et ETI accompagnes par AccessPointCompany.

Question de recherche, verrous et hypotheses

La question que j'ai choisi d'explorer peut se formuler ainsi : une methode simple de detection d'anomalies non supervisee peut-elle reduire sensiblement le taux de faux positifs par

rapport a une approche a seuils statiques, tout en restant exploitable avec les faibles volumes de donnees disponibles chez une PME apres seulement quelques semaines de collecte ? Le verrou principal est celui du volume de donnees : la plupart des methodes de detection d'anomalies decrites dans la litterature sont evaluees sur des jeux de donnees bien plus conséquents que ce dont dispose un client typique d'AccessPointCompany. Mon hypothese de depart etait la suivante : une methode non supervisee simple, de type foret d'isolement (Isolation Forest), pourrait deja apporter un gain mesurable par rapport a l'approche a seuils, meme sur un volume de donnees restreint, a condition d'accepter en contrepartie une legere perte de capacite a detecter certains evenements rares.

Etat de l'art

Cadre theorique

La detection d'anomalies en cybersécurité s'inscrit dans un cadre theorique plus large, celui de l'apprentissage non supervise : il s'agit d'identifier, au sein d'un ensemble de donnees, les observations qui s'ecartent significativement du comportement majoritaire, sans disposer au préalable d'exemples etiquetes d'attaques. C'est une difference fondamentale avec les approches de classification supervisee, plus repandues dans d'autres domaines de l'intelligence artificielle, mais moins adaptees a la cybersécurité ou les attaques reelles sont rares et tres variees, ce qui rend difficile la constitution d'un jeu d'entrainement etiquete representatif.

Que sait-on deja ?

La litterature distingue plusieurs grandes familles de methodes de detection d'anomalies applicables aux journaux de securite. Les methodes fondees sur des arbres de decision aleatoires, dont la foret d'isolement (Isolation Forest, proposee par Liu, Ting et Zhou en 2008) est la plus connue, isolent les observations anormales en un nombre de decoupages plus faible que les observations normales, sans necessiter d'hypothese sur la distribution des donnees. Les methodes fondees sur des reseaux de neurones, en particulier les auto-encodeurs, apprennent a reconstruire les observations normales et signalent comme anormales celles que le modele reconstruit mal ; elles sont plus puissantes sur de gros volumes mais plus couteuses a entrainer et plus difficiles a interpreter. Enfin, des methodes specifiquement pensees pour les series temporelles, comme les reseaux recurrents de type LSTM utilises pour la detection d'anomalies multi-capteurs, sont mieux adaptees a des flux continus mais demandent generalement un historique important pour bien apprendre la notion de «normalite».

Etat actuel des connaissances

a) Solutions industrielles (R&D). Plusieurs editeurs proposent deja des briques de detection comportementale, regroupees sous l'appellation UEBA (User and Entity Behavior Analytics) : Microsoft Sentinel integre des modeles de detection d'anomalies dans ses regles analytiques, Splunk propose un module UBA dedie, et des SIEM open source comme Wazuh commencent a integrer des regles de scoring plus fines que le simple seuil. Ces solutions restent neanmoins couteuses ou complexes a deployer pour une PME, ce qui confirme l'ecart entre

l'état de l'art industriel et les moyens reels des clients accompagnes par AccessPointCompany.

b) Approches de recherche academique. Du cote academique, de nombreux travaux ont etudie l'application de methodes non supervisees a la detection d'intrusion reseau et a l'analyse de journaux d'authentification, en particulier a partir du milieu des annees 2010, avec une attention croissante portee a la question du volume de donnees necessaire et de l'interpretabilite des modeles pour des equipes non specialistes – deux limites directement pertinentes pour mon propre contexte. C'est precisement sur cette derniere question, peu traitee a l'echelle d'une petite structure, que j'ai souhaite apporter une premiere contribution exploratoire, necessairement modeste au regard de mon niveau actuel.

Methodes et materiaux

Pour repondre a ma question de recherche sans mobiliser de donnees client reelles – une contrainte de confidentialite que je me suis imposee des le depart, en accord avec mon tuteur – j'ai construit un protocole experimental en trois etapes, mene sur mon temps personnel en complement de mes missions.

Etape 1. Generation d'un jeu de donnees synthetique. A l'aide d'un petit script Python, j'ai genere un jeu de donnees simulant environ trois mille evenements de connexion sur une periode de six semaines, reprenant la structure des journaux observes en mission 5 (horodatage, identifiant utilisateur, resultat de la tentative, nouvel appareil ou non) mais entierement fictif. J'ai introduit une minorite d'evenements anormaux (environ 4 % du jeu de donnees), certains representatifs d'attaques plausibles (tentatives repetees rapprochees), d'autres representatifs de faux positifs plausibles (connexion legitime a une heure inhabituelle).

Etape 2. Mise en œuvre de la ligne de base. J'ai reproduit, sur ce jeu de donnees, la logique des regles a seuils utilisees en mission 5 : plus de trois echecs de connexion en moins de cinq minutes, ou connexion reussie en dehors de la plage sept heures – vingt heures.

Etape 3. Mise en œuvre d'une methode non supervisee. J'ai entraine un modele de foret d'isolement, a l'aide de la bibliotheque scikit-learn, sur quatre variables simples construites a partir des journaux : l'heure de la connexion, le nombre de tentatives echouees dans les dix minutes precedentes, un indicateur de nouvel appareil, et le nombre de connexions du meme utilisateur dans les dernieres vingt-quatre heures.

Extrait du code utilise pour l'entrainement du modele

```
from sklearn.ensemble import IsolationForest
import pandas as pd

logs = pd.read_csv("journaux_synthetiques.csv")
features = logs[["heure", "echecs_10min", "nouvel_appareil", "connexions_24h"]]

modele = IsolationForest(
    n_estimators=200,
    contamination=0.04, # proportion d'anomalies attendue
```

```

    random_state=42
)
modele.fit(features)

logs["score_anomalie"] = modele.decision_function(features)
logs["anomalie_predite"] = modele.predict(features) == -1

```

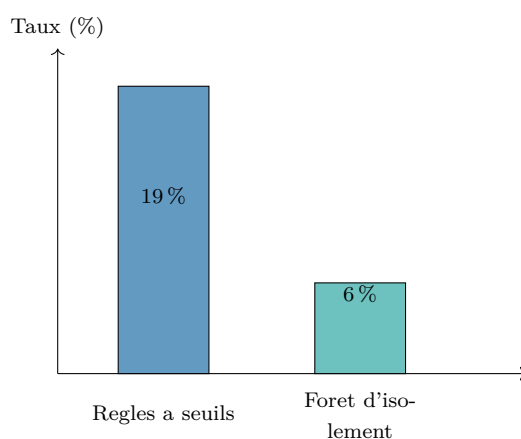
J'ai ensuite compare les deux approches sur un jeu de test representant 30 % des donnees, non utilise pour l'entrainement, a l'aide de trois indicateurs classiques : le rappel (proportion des anomalies reelles correctement detectees), le taux de faux positifs (proportion d'evenements normaux signales a tort) et le nombre absolu d'alertes generees par semaine, cette derniere mesure etant, d'apres mon experience de la mission 5, aussi importante pour une petite equipe que les indicateurs statistiques eux-memes.

Resultats

Les resultats obtenus sur mon jeu de donnees synthetique sont resumes dans le tableau ci-dessous.

Indicateur	Regles a seuils (baseline)	Foret d'isolement
Rappel (anomalies detectees)	94 %	81 %
Taux de faux positifs	19 %	6 %
Alertes generees par semaine (moyenne)	27	9

Taux de faux positifs compare (baseline vs. foret d'isolement)



Ces resultats confirment partiellement mon hypothese de depart : la foret d'isolement divise par plus de trois le taux de faux positifs et le nombre d'alertes hebdomadaires, ce qui correspond directement au probleme identifie en mission 5, ou le volume d'alertes non pertinentes decourageait le suivi regulier du dispositif. En contrepartie, le rappel baisse de treize points, ce qui signifie concretement que la methode non supervisee laisse passer une part non negligeable des anomalies simulees, en particulier celles dont les caracteristiques se rapprochent le plus du comportement normal.

Discussion

Signification des resultats

Ces resultats confirment, sur un jeu de donnees certes limite et synthetique, l'intuition issue de mon experience de terrain : une methode non supervisee simple peut apporter un gain reel sur le volume d'alertes a traiter, ce qui est precisement ce qui manquait au dispositif mis en place en mission 5. Sur le plan de l'acquisition de connaissances, cet exercice m'a surtout appris a raisonner en termes de compromis plutot que de solution absolue : reduire les faux positifs a un cout, ici une baisse du rappel, qu'il faut mettre en balance avec les contraintes reelles du client.

Questions ouvertes

Plusieurs questions restent ouvertes a l'issue de ce travail exploratoire. La premiere concerne le volume de donnees minimal necessaire pour qu'un modele de ce type reste fiable dans la duree, une question que je n'ai pas pu traiter serieusement faute de disposer de plusieurs mois de donnees, meme synthetiques. La seconde concerne l'interpretabilite : un score d'anomalie produit par un modele est plus difficile a expliquer a une petite equipe IT qu'une regle explicite, ce qui pourrait nuire a l'adoption d'une telle approche chez les clients d'AccessPointCompany, dont la culture, evoquee au chapitre precedent, privilegie justement la simplicite operationnelle. La troisieme concerne la stabilite du modele dans le temps : les habitudes de connexion d'une organisation evoluent, et un modele entraine une fois pourrait se degrader progressivement sans mecanisme de reentrainement, une problematique que je n'ai pas eu le temps d'etudier.

Analyse critique

Je reste prudent sur la portee de ces resultats. Le jeu de donnees utilise est synthetique et de taille modeste, construit par mes soins a partir d'hypotheses simplificatrices sur ce qu'est un comportement «normal» ou «anormal», ce qui peut avoir favorise artificiellement la methode non supervisee. Je n'ai teste qu'un seul algorithme parmi ceux recenses dans l'etat de l'art, et je n'ai pas eu l'occasion de confronter ces resultats a un cas reel, pour des raisons de confidentialite mais aussi parce que je ne dispose pas encore, a ce stade de ma formation, du niveau d'autonomie necessaire pour deployer ce type de solution chez un client. Ce travail doit donc etre lu comme une premiere exploration personnelle, et non comme une preuve robuste de la superiorite d'une approche sur l'autre.

Conclusion du chapitre

Contributions techniques. Ce chapitre a permis de construire un protocole experimental reproductible – generation de donnees synthetiques, baseline a regles, modele non supervise, comparaison sur des indicateurs adaptes aux contraintes d'une petite equipe – et d'obtenir un premier resultat chiffre montrant qu'une methode de detection d'anomalies simple peut diviser significativement le volume de faux positifs par rapport a l'approche a seuils utilisee en mission 5, au prix d'une baisse mesuree du rappel.

Limites. Ce travail reste une exploration personnelle et modeste : donnees synthetiques et

non reelles, un seul algorithme teste, absence de validation sur la duree, et absence de confrontation avec un cas client reel pour des raisons de confidentialite et de niveau d'autonomie.

Travaux futurs. Je souhaiterais, si l'occasion se presente dans la suite de ma carriere, pouvoir tester cette approche sur des donnees reelles anonymisees, avec l'accord explicite d'un client et sous la supervision d'un consultant senior, et explorer une approche hybride combinant les regles explicites – pour leur transparence – et un score d'anomalie complementaire – pour leur capacite a capter des signaux faibles, dans une logique d'aide a la decision plutot que de remplacement pur et simple du dispositif existant.

5. Bilan de l'année écoulée

Compétences développées, acquises et manquantes

Compétences techniques

Cette année m'a permis de développer des compétences que je ne maîtrisais qu'en théorie l'année précédente : une lecture plus fine des référentiels ISO 27001 et ISO 22301, une première pratique réelle – bien qu'encadrée – du test d'intrusion, une découverte du fonctionnement d'un projet de certification de l'intérieur, et une première approche, encore limitée, de la supervision de sécurité et des risques fournisseurs.

Compétences transverses et humaines

J'ai également développé des compétences transverses : vulgarisation d'un résultat technique pour un public non technique, gestion de plusieurs dossiers en parallèle sans perdre en qualité, une première expérience de communication commerciale à l'occasion des rendez-vous avant-vente, et une première expérience, modeste, de transmission auprès d'une collègue plus junior que moi.

Compétences manquantes

A l'inverse, je considère que certaines compétences me manquent encore pour être pleinement opérationnel sur les missions les plus avancées que j'ai pu observer cette année : la sécurité des environnements cloud (AWS, Azure), les pratiques DevSecOps et la sécurisation des chaînes d'intégration continue, une connaissance plus approfondie du droit pénal du numérique, ainsi que les techniques d'investigation numérique (forensic) avancées, dont je n'ai vu qu'un aperçu très limité lors de la mission 4.

Enseignement ESILV	Mobilisation durant l'alternance
Gestion des risques et référentiels de sécurité	Application quotidienne de la méthode EBIOS et des normes ISO 27001 / 22301
Cryptographie	Compréhension des mécanismes d'authentification et de chiffrement audites
Architecture réseau sécurisée	Lecture des infrastructures clientes lors des audits et tests d'intrusion
Droit du numérique et protection des données	Prise en compte du RGPD, découverte approfondie de NIS2 et DORA
Gestion de projet et travail en équipe	Suivi de plusieurs dossiers en parallèle, collaboration avec Nawel et Amine

Lien avec ma majeure

La majeure Cybersecurity et Réseaux (OCC) suivie à l'ESILV a été directement mobilisée tout au long de cette année, comme le montre le tableau ci-dessus. Les cours de gestion des risques m'ont donné le cadre théorique nécessaire pour comprendre et appliquer la méthode EBIOS, les enseignements en architecture réseau m'ont aidé à mieux lire les infrastructures

auditees, et les cours de droit du numerique m'ont permis de comprendre les enjeux reglementaires (RGPD, NIS2, DORA) rencontres sur le terrain. Cette annee a confirme que la majeure choisie correspond bien au metier que je souhaite exercer, meme si elle a egalement revele des zones – cloud, DevSecOps – ou mes enseignements academiques restent encore theoriques par rapport a ce qu'exige le terrain.

Je note egalement que la maniere dont l'ESILV structure ses enseignements en travaux pratiques et en projets de groupe m'a directement prepare a la logique des missions en binome que j'ai vecues cette annee, notamment lors des tests d'intrusion : la meme discipline de documentation, de repartition des taches et de restitution structuree que celle demandee dans nos projets d'ecole s'est retrouvee, presque a l'identique, dans mon quotidien professionnel.

Difficultes rencontrees et solutions apportees

La principale difficulte de cette annee a ete de trouver le bon niveau d'autonomie : au debut de l'annee, j'ai parfois hesite a solliciter mon tuteur sur des sujets ou je pensais devoir me debrouiller seul, ce qui m'a fait perdre du temps sur au moins un dossier. La solution que j'ai mise en place, avec l'aide de mon tuteur, a ete d'instaurer un point hebdomadaire court pour faire le point sur mes dossiers en cours, ce qui m'a permis de solliciter de l'aide plus tot lorsque c'etait necessaire.

Une seconde difficulte a ete la contribution au projet ISO 27001 interne : documenter des ecart qui concernaient mon propre environnement de travail m'a mis mal a l'aise au debut, par crainte de pointer du doigt des pratiques de mes collegues. J'ai appris, avec les conseils de mon tuteur, a presenter les constats de maniere factuelle et centree sur l'amelioration collective plutot que sur la recherche de responsables.

Une troisieme difficulte a ete d'ordre technique et deja evoquee plus haut : la gestion des faux positifs lors des scans automatises sur des infrastructures anciennes, qui m'a demande de developper de la rigueur et de la patience, avec l'appui d'Amine pour verifier mes conclusions.

Enfin, accompagner Nawel tout en continuant a apprendre moi-meme n'a pas toujours ete simple : il m'est arrive de lui transmettre des explications encore imparfaites. Cela m'a appris a etre plus rigoureux dans ma propre comprehension avant de l'expliquer a quelqu'un d'autre, et a ne pas hesiter a lui dire quand je n'etais pas sur d'une reponse – une posture d'humilite que je considere aujourd'hui comme une competence a part entiere.

Succes, bonnes pratiques et positionnement par rapport aux objectifs initiaux

Sur les trois objectifs fixes en debut d'annee, je considere avoir atteint le premier – gagner en autonomie sur les missions deja maitrisees – de maniere satisfaisante : les audits de vulnerabilite et la cartographie des risques fournisseurs ont ete menes de maniere largement autonome, avec une relecture finale de mon tuteur. Le deuxieme objectif, elargir mon perimetre technique, a egalement ete atteint, meme si ma contribution sur les tests d'intrusion et la supervision de securite reste encore celle d'un binome plutot que d'un consultant autonome sur ces sujets. Le troisieme objectif, decouvrir la dimension GRC du metier via le projet ISO 27001 interne, a ete pour moi le plus reussi et le plus marquant de l'annee.

Parmi les bonnes pratiques que je retiens : le point hebdomadaire avec mon tuteur, qui a nettement amélioré ma gestion du temps et ma capacité à demander de l'aide ; la vérification systématique des résultats des outils automatisés avant de les intégrer à un livrable ; et la simplicité opérationnelle privilégiée par AccessPointCompany dans ses livrables, une philosophie que j'ai essayé d'appliquer moi-même dans mes propres restitutions. Comme axe d'amélioration pour la suite, je souhaite continuer à développer mon autonomie sur les tests d'intrusion et la supervision de sécurité, deux sujets sur lesquels je reste aujourd'hui encore junior, ainsi que sur les problématiques de sécurité du cloud, que je n'ai qu'entre aperçues cette année.

Pour objectiver ce positionnement plutôt que de rester sur une impression générale, j'ai construit, avec mon tuteur, une grille d'auto-évaluation simple sur les principaux domaines abordés cette année, en distinguant quatre niveaux : *decouverte* (première exposition au sujet), *notionnel* (je comprends les enjeux mais je ne suis pas opérationnel seul), *opérationnel encadré* (je peux réaliser la tâche seul, sous supervision ou avec relecture) et *autonome* (je peux réaliser la tâche seul, sans relecture systématique).

Domaine	Début d'année	Fin d'année
Audit de vulnérabilité (ISO 27001/22301)	Opérationnel encadré	Autonome
Plan de continuité d'activité	Opérationnel encadré	Autonome
Analyse de risques EBIOS	Notionnel	Opérationnel encadré
Test d'intrusion	Découverte	Opérationnel encadré (en binôme)
Analyse post-incident	Découverte	Notionnel
Supervision de sécurité (SOC)	Découverte	Notionnel
Cartographie des risques fournisseurs	Découverte	Opérationnel encadré
Communication et vulgarisation client	Notionnel	Opérationnel encadré
Sécurité des environnements cloud	Découverte	Découverte

Cette grille confirme le constat qualitatif fait plus haut : ma progression est réelle sur les sujets déjà abordés en première année, plus timide sur les sujets nouveaux comme le test d'intrusion ou la supervision, et quasiment nulle sur des sujets que je n'ai qu'effleurés, comme la sécurité du cloud. Je considère que c'est une photographie honnête de mon niveau actuel, sans exagération ni fausse modestie.

Retours de mon tuteur et de mes pairs

Pour ne pas fonder ce bilan uniquement sur mon propre ressenti, j'ai demandé à mon tuteur et à Amine de me faire un retour écrit sur mon évolution cette année, en toute franchise.

Retour d'Amir Achache, tuteur d'alternance

"Samy a fait de réels progrès cette année, en particulier sur sa capacité à structurer un dossier et à savoir quand solliciter de l'aide plutôt que de rester bloqué seul. Il reste encore junior sur les sujets les plus techniques comme le pentest ou la supervision, ce qui est

normal a ce stade, mais sa rigueur sur les audits et sa contribution au projet ISO 27001 interne ont ete au-dessus de ce que j'attendais d'un alternant de son niveau."

Retour d'Amine, alternant IT-Cybersecurite

"Ce qui a change chez Samy cette annee, c'est qu'il pose des questions plus precises qu'avant, et qu'il vient me voir avec une hypothese deja construite plutot qu'avec un probleme brut. Sur les scans de vulnerabilite avec beaucoup de faux positifs, il a ete tres perseverant. Il a encore des choses a apprendre sur la partie supervision, comme moi d'ailleurs."

Ces deux retours convergent avec ma propre auto-evaluation : une progression reelle et reconnue par mon entourage professionnel, mais qui reste celle d'un alternant en cours de formation, et non celle d'un consultant confirme.

Plan de carriere a court et moyen terme

A court terme, a l'issue de ce cycle ingenieur, je souhaite integrer un poste de consultant junior en cybersecurite, idealement dans une structure ou je pourrai continuer a etre accompagne par des profils seniors, comme cela a ete le cas chez AccessPointCompany. Je souhaite egalement passer une premiere certification professionnelle reconnue dans le secteur, par exemple ISO 27001 Lead Implementer ou une certification technique de type CEH, dans les deux prochaines annees, pour consolider les bases acquises durant mon alternance et combler certaines des lacunes identifiees plus haut, notamment sur le cloud.

A moyen terme, sur un horizon de trois a cinq ans, je souhaite continuer a monter en competence vers un role de consultant confirme, avec une specialisation progressive dans la gouvernance, les risques et la conformite (GRC), un axe que la contribution au projet de certification ISO 27001 interne d'AccessPointCompany m'a permis de decouvrir et qui correspond, je le pense, a la maniere dont je souhaite exercer ce metier : allier la rigueur technique acquise pendant mes deux annees d'alternance a une comprehension plus strategique des enjeux de securite des organisations. Je garde a l'esprit qu'il s'agit d'une trajectoire progressive, et que je n'en suis aujourd'hui qu'au tout debut.

Conclusion

Ces deux annees d'alternance chez AccessPointCompany ont ete determinantes pour moi. La premiere m'avait ouvert les yeux sur la dimension humaine de la cybersecurite ; cette seconde annee m'a appris que gagner en autonomie est un processus progressif, qui passe par la capacite a solliciter les bonnes personnes au bon moment, et non par le fait de travailler seul. J'ai decouvert qu'etre un bon consultant en cybersecurite, ce n'est pas seulement savoir trouver des vulnerabilites ou construire un plan de continuite, c'est aussi savoir apprendre en continu, accepter d'etre encore accompagne sur certains sujets, et commencer, humblement, a transmettre ce que l'on sait a ceux qui arrivent apres nous.

Pour répondre à la problématique posée en introduction, je crois pouvoir dire que ma progression cette année n'est pas passée par une autonomie totale et soudaine, mais par une série de petits pas : un dossier mène seul ici, un binôme bien accompagne la, une question posée à temps plutôt que trop tard. C'est cette accumulation de petites responsabilités, plus que la prise en charge d'un unique grand projet, qui a fait de moi un alternant plus mature en fin d'année qu'au début.

Cette expérience de fin de cycle a été décisive dans la définition de mon projet professionnel : je souhaite désormais m'orienter vers un métier à l'intersection de la technique et de la gouvernance, dans la continuité directe de ce que j'ai commencé à découvrir sur le projet de certification ISO 27001 d'AccessPointCompany. J'aborde la suite de ma carrière consciente qu'il me reste encore beaucoup à apprendre, en particulier sur le cloud, la supervision de sécurité et le test d'intrusion, mais avec la conviction d'avoir trouvé un métier, une équipe et une manière d'exercer ce métier qui me correspondent.

En relisant ce mémoire, ainsi que celui rédigé un an plus tôt, je mesure à quel point ces deux années ont été complémentaires : la première m'a donné les fondamentaux du métier, la seconde m'a appris à les mettre en œuvre avec un peu plus de recul, de responsabilité et de discernement sur quand agir seul et quand demander de l'aide. C'est avec cette double leçon, technique et humaine, que je quitte aujourd'hui le statut d'alternant pour entamer la suite de mon parcours professionnel.

Glossaire et liste des sigles

Sigle	Signification
ANSSI	Agence Nationale de la Securite des Systemes d'Information
COMEX	Comite Executif
CVSS	Common Vulnerability Scoring System, echelle de notation de la criticite d'une vulnerabilite
DD-RSE	Developpement Durable et Responsabilite Societale des Entreprises
DORA	Digital Operational Resilience Act, reglement europeen sur la resilience operationnelle numerique du secteur financier
EBIOS	Expression des Besoins et Identification des Objectifs de Securite, methode d'analyse de risques
EDR	Endpoint Detection and Response
ENISA	Agence de l'Union europeenne pour la cybersecurite
ESN	Entreprise de Services du Numerique
GRC	Gouvernance, Risques et Conformite
NIS2	Network and Information Security 2, directive europeenne de cybersecurite
PCA	Plan de Continuite d'Activite
PRA	Plan de Reprise d'Activite
RGPD	Reglement General sur la Protection des Donnees
RPO	Recovery Point Objective, perte de donnees maximale tolerable
RTO	Recovery Time Objective, duree maximale d'indisponibilite tolerable
SIEM	Security Information and Event Management
SMSI	Systeme de Management de la Securite de l'Information
SoA	Statement of Applicability, declaration d'applicabilite (ISO 27001)
SOC	Security Operations Center, centre de supervision de securite

Annexes

Les elements ci-dessous sont des emplacements reserves, a completer avec les captures d'ecran, extraits de rapports et supports reels produits durant l'annee, dans le respect de la confidentialite des clients concernes. Ils sont presentes dans l'ordre ou les missions correspondantes ont ete decrites dans le corps de ce memoire, afin de faciliter la lecture croisee entre le texte et les pieces justificatives.

Declaration d'applicabilite (SoA) – projet ISO 27001 interne AccessPoint-Company

Extrait de la Statement of Applicability recensant les mesures de l'Annexe A ISO 27001 retenues, avec justification de l'inclusion ou de l'exclusion pour chaque mesure.

Emplacement reserve a la capture d'ecran reelle – a inserer avec \includegraphics.

Dashboard de supervision de securite

Tableau de bord centralisant les alertes de securite d'un client, avec code couleur par criticite et flux de logs agreges.

Emplacement reserve a la capture d'ecran reelle – a inserer avec \includegraphics.

Resultats de la campagne de simulation de phishing

Graphique comparant le taux de clic sur emails de phishing simules avant et apres la session de sensibilisation ciblee (34% puis 9%).

Emplacement reserve a la capture d'ecran reelle – a inserer avec \includegraphics.

Chronologie simplifiee – analyse d'incident rancongiel

Chronologie reconstituee de la propagation de l'attaque, du vecteur d'entree initial jusqu'au chiffrement partiel des serveurs de fichiers.

Emplacement reserve a la capture d'ecran reelle – a inserer avec \includegraphics.

Cartographie des risques fournisseurs (tiers)

Matrice de criticite des prestataires tiers d'un client, croisant niveau d'acces au systeme d'information et sensibilite des donnees traitees.

Emplacement reserve a la capture d'ecran reelle – a inserer avec \includegraphics.

Extrait de rapport d'audit de vulnérabilité

Page de synthèse d'un rapport d'audit, présentant les vulnérabilités classées par criticité et les recommandations associées.

Emplacement réservé à la capture d'écran réelle – à insérer avec \includegraphics.

Support de restitution – test d'intrusion en binôme

Extrait du rapport de test d'intrusion présentant la faille identifiée et son niveau de risque business.

Emplacement réservé à la capture d'écran réelle – à insérer avec \includegraphics.

Grille de scoring des risques enrichie du critère réglementaire

Grille de criticité des actifs intégrant le rôle de l'actif, la sensibilité des données, la résistance aux attaques et l'exposition réglementaire (DORA, NIS2, RGPD).

Emplacement reserve a la capture d'ecran reelle – a inserer avec \includegraphics.

Retroplanning de l'annee d'alternance

Vue synthetique du plan de route de l'annee, presente en section 2.2, sous forme de frise chronologique annotee.

Emplacement reserve a la capture d'ecran reelle – a inserer avec \includegraphics.

Extrait de la base de connaissances interne du pole IT-Cybersecurite

Sommaire de la base de connaissances alimentee en fin d'annee, recensant les procedures et modeles de documents les plus utilises par l'equipe.

Emplacement reserve a la capture d'ecran reelle – a inserer avec \includegraphics.